Your logo

My Company
United States

Security & GRC Scorecard

Assessment #1 · 11/01/2026 02:13:51 · Odoo 18.0-20261015 Community

D	46/100	16%
Grade	Security score	GRC compliance

Money at risk (open cases)

$ 27,900.00

3 case(s) to review (4 alerts)

Paid by users holding toxic rights (12 months)

$ 26,350.00

2 user(s) with conflicting rights

Return on security investment (ROSI)

Scenario	Annual cost	Net benefit / yr	ROSI	Break-even annual chance
Conservative	$ 2,990.00	$ -2,711.00	-91%	54%
Base	$ 2,090.00	$ -918.20	-44%	18%
Aggressive	$ 1,490.00	$ 2,081.20	140%	8%

If a loss of $ 27,900.00 recurs once a year. Cost = Shield licence + alert-review labour. Probability, recovery, hold effectiveness and labour are estimates, not benchmarks.

Cases to review

Severity	Incident	Why	At risk
Critical	**Acme Industrial Supplies · GB29NWBK60161331926819** by ana.ap	Bank account changed before payment, Bank account trusted by the person who changed it	**$ 18,400.00**
High	**Northwind Logistics · PBNK1/2026/00003** by ana.ap	Bill paid by the person who entered it	**$ 4,750.00**
Medium	**Northwind Logistics · BILL/2026/10/0002** by ana.ap	Duplicate vendor bill	**$ 4,750.00**

Top 3 fixes

1. **Payments to new bank details are held** (Critical): Payments to freshly changed bank accounts are only detected, not stopped. Turn on Shield's payment hold (one-click fix) to require a second person to verify any account number set in the last 30 days before money leaves.
   Apply the one-click fix, then brief AP: when a payment is held, a colleague calls the vendor on a number you already had and clicks "Verify with Shield" on the bank account.

2. **No one can redirect and pay alone** (Critical): 2 user(s) can change a vendor's bank account, mark it trusted and pay it alone, which defeats Odoo's bank-account validation safeguard: admin ($ 3,200.00), ana.ap ($ 23,150.00). 2 of them created $ 26,350.00 of payments in the last 12 months.
   Take "Validate bank account" away from anyone who creates payments; give it to a controller who does not pay. Remove partner-management rights from payment clerks if possible.
3. **User administrators do not pay** (Critical): 1 user(s) can grant themselves any right, then pay: admin ($ 3,200.00). 1 of them created $ 3,200.00 of payments in the last 12 months.
   Use a dedicated administrator account that is not used for accounting work; remove Billing rights from it.

Framework compliance

Framework	Satisfied	Applicable	Compliance
ISO/IEC 27001:2022 Annex A	1	18	6%
SOC 2 Trust Services Criteria	1	12	8%
CIS Critical Security Controls	6	18	33%

All controls

Status	Severity	Control	Detail
Fail	Critical	No default 'admin' account	The 'admin' account still has the default password 'admin'.
Fail	Critical	Strong, hashed master password	The master password is a common default.
Fail	Critical	Automated off-site backups	No attestation recorded. Record evidence under Shield > Attestations.
Fail	Critical	Payments to new bank details are held	Payments to freshly changed bank accounts are only detected, not stopped. Turn on Shield's payment hold (one-click fix) to require a second person to verify any account number set in the last 30 days before money leaves.
Fail	Critical	No one can redirect and pay alone	2 user(s) can change a vendor's bank account, mark it trusted and pay it alone, which defeats Odoo's bank-account validation safeguard: admin ($ 3,200.00), ana.ap ($ 23,150.00). 2 of them created $ 26,350.00 of payments in the last 12 months.
Fail	Critical	User administrators do not pay	1 user(s) can grant themselves any right, then pay: admin ($ 3,200.00). 1 of them created $ 3,200.00 of payments in the last 12 months.
Fail	Critical	No payments to freshly changed bank accounts	1 payment(s) to recently changed bank accounts to review, touching $ 18,400.00: PBNK1/2026/00002 to Acme Industrial Supplies: account number changed by ana.ap 0 day(s) before payment by ana.ap
Fail	Critical	Bank accounts verified by a second person	1 self-verified bank account(s) to review, touching $ 18,400.00: GB29NWBK60161331926819 of Acme Industrial Supplies changed and trusted by the same person (ana.ap); 1 payment(s) since
Fail	High	Two-factor authentication in use	1 administrator(s) without 2FA: admin
Fail	High	Two-factor authentication enforced	2FA is optional; users can log in with a password only.
Fail	High	Database manager disabled	The database manager and database list are enabled (list_db = True). Anyone holding the master password can download or drop databases.
Fail	High	Strong, least-privilege database credentials	Database credentials are weak: the database password is a common default ('od***'). Odoo connects over the network to host 'db'; anyone who reaches PostgreSQL bypasses every Odoo access rule and audit trail.

Your logo

My Company
United States

Status	Severity	Control	Detail
Fail	High	Restore tested in the last 90 days	No attestation recorded. Record evidence under Shield > Attestations.
Fail	High	Quarterly user access review	No attestation recorded. Record evidence under Shield > Attestations.
Fail	High	Bill entry separated from payment	2 user(s) can enter a vendor bill and pay it without a second person: admin ($ 3,200.00), ana.ap ($ 23,150.00). 2 of them created $ 26,350.00 of payments in the last 12 months.
Fail	High	Bills not paid by the person who entered them	1 bill(s) paid by the person who entered them to review, touching $ 4,750.00: ana.ap entered BILL/2026/10/0001 and paid it with PBNK1/2026/00003
Fail	Medium	Password length policy	No password policy module installed.
Fail	Medium	No free self sign-up	Anyone can create a portal account (free sign-up).
Fail	Medium	Evidence seals kept outside Odoo	Assessment seals only live inside this database: an administrator could delete or rewrite the whole history. Set the system parameter shield.seal_recipients to an external mailbox (e.g. your auditor or board) to receive each seal.
Fail	Medium	Separate staging environment	No attestation recorded. Record evidence under Shield > Attestations.
Fail	Medium	Production change process	No attestation recorded. Record evidence under Shield > Attestations.
Fail	Medium	Incident response plan	No attestation recorded. Record evidence under Shield > Attestations.
Fail	Medium	No duplicate vendor bills	1 possible duplicate bill(s) to review, touching $ 4,750.00: BILL/2026/10/0002 duplicates BILL/2026/10/0001 (Northwind Logistics, $ 4,750.00)
Warning	Medium	Multi-process mode with limits	workers = 0: single process without memory/time limits; one heavy request can stall every user.
Warning	Low	Database selection restricted	No dbfilter: any database on the server can be selected by URL.
Warning	Low	HTTPS everywhere	Base URL is local plain HTTP (http://localhost:8090); fine for testing only.
Warning	Low	Supported Odoo version	Odoo 18.0 is supported but 1 major version(s) behind 19.0.
Pass	Critical	Shield itself not tampered with	All Shield controls, the schedule and previously passing protections are intact.
Pass	Critical	Audit trail not erased	No audit-trail messages deleted from existing records in the last 30 days.
Pass	Critical	Bank account changes always leave a trace	No bank account change(s) hidden from the audit trail in the last 12 months.
Pass	High	Limited Settings administrators	1 Settings administrator(s).
Pass	High	No unexpected new administrators	Baseline of privileged users recorded (1 with Settings).
Pass	High	Brute-force protection on	Login cooldown after 10 failures for 60 seconds.
Pass	High	No brute force, spraying or takeover	0 failed login(s) in the last 24 hours; no attack pattern.
Pass	High	Record rules come from reviewed modules	All record rules come from installed modules.
Pass	High	No public attachments on business documents	No public attachments on business documents.
Pass	High	Developer mode off in production	Developer mode is off server-wide.

Your logo

My Company
United States

Status	Severity	Control	Detail
Pass	High	No unreviewed code stored in the database	All server-side code comes from installed modules.
Pass	High	No bulk exports of sensitive data	No bulk export of sensitive data in the last 30 days. 1 user(s) hold export rights.
Pass	High	Odoo build patched	Build 18.0-20261015 is 17 days old; no known advisory applies.
Pass	High	No bank account shared between unrelated contacts	No bank account(s) shared between unrelated contacts in the last 12 months.
Pass	High	No lookalike vendors	No lookalike vendor(s) in the last 12 months.
Pass	High	New vendors not paid at once by their creator	No new vendor(s) paid within a week by their creator in the last 12 months.
Pass	Medium	No dormant internal accounts	No internal account idle for more than 90 days.
Pass	Medium	Segregation of duties in accounting	1 accounting administrator(s).
Pass	Medium	Dynamic templates restricted to administrators	Only administrators can write dynamic templates.
Pass	Medium	Scheduled actions healthy	No failing scheduled actions.
Pass	Medium	Module code and database in sync	All module code matches the database (46 modules).
Pass	Low	API keys owned and rotated	No API keys issued.
Pass	Low	Outgoing email delivered	No failed outgoing emails.
Pass	Low	Third-party modules reviewed	Only official Odoo modules installed.
Not applicable	High	Third-party code free of risky patterns	No third-party modules installed.
Not applicable	Medium	Custom modules restrict write access	No third-party modules installed.
Not applicable	Medium	Outgoing mail uses TLS	No custom outgoing mail server configured.

Framework mappings support evidence collection and are not a certification. Scores reflect controls measured at the time of the assessment.

Evidence seal (SHA-256, chained to the previous assessment): 9e0052bc3b859ef5ec198c79a2b2ad388f01057ef8489b69ce46bdc9b922ccf7